1. Which of the following is a type of social engineering attack?

a) SQL injection

b) Cross-site scripting

c) Phishing

d) Buffer overflow

Answer: c) Phishing

Explanation: Phishing is a type of social engineering attack that involves tricking people into giving sensitive information such as login credentials or credit card numbers. The attacker might use a fake website or email that appears to be from a legitimate source to trick the victim into revealing their information.

2. What is the main purpose of a port scanner?

a) To identify vulnerabilities in software

b) To encrypt network traffic

c) To identify open ports on a network

d) To monitor network traffic

Answer: c) To identify open ports on a network

Explanation: A port scanner is a tool that is used to identify open ports on a network. This information can be used by attackers to identify vulnerable systems or services that can be exploited.

3. Which of the following is a type of password attack?

a) Brute force

b) Cross-site scripting

c) SQL injection

d) Denial of Service

Answer: a) Brute force

Explanation: Brute force is a type of password attack that involves trying every possible combination of characters until the correct password is found. This type of attack can be time-consuming but is effective against weak or simple passwords.

4. Which of the following is a way to prevent SQL injection attacks?

a) Encrypting network traffic

b) Implementing a firewall

c) Input validation

d) Installing antivirus software

Answer: c) Input validation

Explanation: Input validation is a technique used to prevent SQL injection attacks by ensuring that user input is validated and sanitized before it is sent to a database. This can prevent malicious code from being injected into a query and executed.

5. Which of the following is a type of denial of service attack?

a) Smurf attack

b) SQL injection

c) Cross-site scripting

d) Port scanning

Answer: a) Smurf attack

Explanation: A Smurf attack is a type of denial of service attack that involves sending a large number of ICMP echo requests (pings) to a network broadcast address. This causes all devices on the network to reply to the requests, overwhelming the network and making it inaccessible to legitimate traffic.

6. Which of the following is NOT an example of a social engineering technique?

a) Pretexting

b) Phishing

c) Shoulder surfing

d) SQL injection

Answer: d) SQL injection

Explanation: Social engineering refers to the use of psychological manipulation techniques to trick people into divulging sensitive information. Pretexting, phishing, and shoulder surfing are all examples of social engineering techniques. SQL injection, on the other hand, is a type of cyber attack that targets databases.

7. Which of the following is an example of a passive network reconnaissance technique?

a) Port scanning

b) Ping sweep

c) Banner grabbing

d) Sniffing

Answer: d) Sniffing

Explanation: Passive network reconnaissance techniques involve gathering information about a network without actively sending traffic to it. Sniffing is an example of a passive network reconnaissance technique because it involves capturing and analyzing network traffic without actively sending traffic to the network.

8. Which of the following is NOT an example of a cryptography algorithm?

a) AES

b) RSA

c) SHA

d) SQL

Answer: d) SQL

Explanation: Cryptography algorithms are used to encrypt and decrypt data. AES, RSA, and SHA are all examples of cryptography algorithms. SQL, on the other hand, is a programming language used to manage and manipulate databases.

9. Which of the following is a technique used to prevent a buffer overflow attack?

a) Input validation

b) Brute force attack

c) Man-in-the-middle attack

d) Social engineering attack

Answer: a) Input validation

Explanation: A buffer overflow attack occurs when a program tries to store more data in a buffer than it can hold. Input validation is a technique used to prevent buffer overflow attacks by checking that input data is within expected parameters before it is processed.

10. Which of the following is an example of a black box testing technique?

a) Fuzz testing

b) Penetration testing

c) Vulnerability scanning

d) Source code review

Answer: a) Fuzz testing

Explanation: Black box testing techniques involve testing software without knowledge of its internal workings. Fuzz testing is an example of a black box testing technique because it involves feeding a program with a large amount of random data to see how it responds. Penetration testing, vulnerability scanning, and source code review are all examples of testing techniques that require knowledge of the internal workings of the software being tested.

11. Which of the following is NOT a common method used for social engineering attacks?

A) Pretexting

B) Phishing

C) Vishing

D) Port Scanning

Answer: D) Port Scanning

Explanation: Social engineering attacks involve manipulating people into divulging sensitive information. Common methods include pretexting, phishing, vishing, and smishing. Port scanning, on the other hand, is a technique used to identify open ports and services on a network.

12. Which of the following is a common vulnerability assessment tool used to identify weaknesses in a network?

A) Metasploit

B) Nikto

C) Nessus

D) Wireshark

Answer: C) Nessus

Explanation: Nessus is a popular vulnerability scanner that can identify vulnerabilities, misconfigurations, and other security issues in a network. Metasploit is an exploitation framework, Nikto is a web server scanner, Snort is an intrusion detection system, and Wireshark is a network protocol analyzer.

13. What type of attack is designed to exhaust a network's resources and deny access to legitimate users?

A) Smurf attack

B) SQL injection

C) Cross-site scripting

D) Social engineering

Answer: A) Smurf attack

Explanation: A smurf attack is a type of DoS (denial of service) attack where an attacker sends ICMP (Internet Control Message Protocol) packets with a spoofed source IP address to a network's broadcast address. The hosts in the network will then respond to the spoofed IP address, flooding the target network with traffic and denying access to legitimate users. SQL injection, cross-site scripting, social engineering, and man-in-the-middle attacks are different types of attacks.

14. Which of the following is NOT a common encryption algorithm used to protect data?

A) AES

B) RSA

C) SHA-1

D) Blowfish

Answer: C) SHA-1

Explanation: AES (Advanced Encryption Standard), RSA (Rivest-Shamir-Adleman), Blowfish, and MD5 (Message Digest 5) are all common encryption algorithms used to protect data. SHA-1 (Secure Hash Algorithm 1) is a cryptographic hash function used to generate a fixed-size output from a variable-size input.

15. Which of the following is a method used to hide a message or file inside another message or file?

A) Steganography

B) Cryptography

C) Hashing

D) Brute-force attack

Answer: A) Steganography

Explanation: Steganography is the practice of concealing a message or file within another message or file. Cryptography involves converting a message or data into a code to prevent unauthorized access. Hashing involves converting data of any size into a fixed-size output. Brute-force and dictionary attacks are methods used to crack passwords or encryption keys.

16. Which of the following is NOT a type of social engineering attack?

a) Phishing

b) Shoulder surfing

c) Bluejacking

d) Spoofing

Answer: c) Bluejacking

Explanation: Bluejacking is a form of wireless hacking that involves sending unsolicited messages to Bluetooth-enabled devices. It is not a type of social engineering attack.

17. Which of the following is a common technique used by attackers to exploit buffer overflow vulnerabilities?

a) Cross-site scripting

b) SQL injection

c) DNS spoofing

d) Shellcode injection

Answer: d) Shellcode injection

Explanation: Shellcode injection is a technique used by attackers to exploit buffer overflow vulnerabilities by injecting malicious code into a program's memory space and then executing that code.

18. Which of the following is NOT a step in the vulnerability assessment process?

a) Scanning

b) Enumeration

c) Fuzzing

d) Exploitation

Answer: d) Exploitation

Explanation: Exploitation is not a step in the vulnerability assessment process. The vulnerability assessment process typically involves scanning, enumeration, and fuzzing.

19. Which of the following is a technique used by attackers to gain access to a system by exploiting a weakness in the system's authentication mechanism?

a) Password spraying

b) Port scanning

c) Ping of Death

d) DNS rebinding

Answer: a) Password spraying

Explanation: Password spraying is a technique used by attackers to gain access to a system by trying a small number of commonly used passwords against many user accounts. This technique can be effective against weak passwords or when the attacker has knowledge of the target's password policy.

20. Which of the following is a technique used by attackers to hide their tracks by erasing evidence of their activities from log files?

a) SQL injection

b) Privilege escalation

c) Fileless malware

d) Log tampering

Answer: d) Log tampering

Explanation: Log tampering is a technique used by attackers to hide their tracks by erasing evidence of their activities from log files. This can make it more difficult for defenders to detect and respond to the attack.

21. Which of the following is a passive reconnaissance technique used in ethical hacking?

a) Port Scanning

b) Social Engineering

c) Sniffing

d) SQL Injection

Answer: c) Sniffing

Explanation: Passive reconnaissance techniques involve collecting information without actively engaging with the target system. Sniffing is a technique where an attacker captures and analyzes network traffic to gather information about the target system. Port Scanning, Social Engineering, and SQL Injection are all active reconnaissance techniques.

22. Which of the following is a technique used to hide data in plain sight?

a) Steganography

b) Cryptography

c) Brute-Force Attack

d) SQL Injection

Answer: a) Steganography

Explanation: Steganography is the technique of hiding data within another file or message in a way that is not easily detected. Cryptography is the technique of secure communication that involves converting plain text into a code that only authorized parties can read. Brute-Force Attack is a method of cracking a password by trying all possible combinations. SQL Injection is a technique used to exploit web applications by injecting SQL code into input fields.

23. Which of the following is a vulnerability scanning tool?

a) Metasploit

b) Nmap

c) Wireshark

d) Cain & Abel

Answer: b) Nmap

Explanation: Nmap (Network Mapper) is a popular vulnerability scanning tool used to identify hosts and services on a network. Metasploit is an exploit framework that helps in penetration testing and finding vulnerabilities. Wireshark is a network protocol analyzer used to capture and analyze network traffic. Cain & Abel is a password cracking tool.

24. Which of the following is a technique used to prevent unauthorized access to a network?

a) Encryption

b) Firewall

c) DMZ

d) VLAN

Answer: b) Firewall

Explanation: A firewall is a network security device that monitors and controls incoming and outgoing network traffic based on predefined security rules. Encryption is the process of converting plain text into a code that only authorized parties can read. DMZ (Demilitarized Zone) is a network segment that separates the public-facing servers from the internal network. VLAN (Virtual Local Area Network) is a logical grouping of devices within a network that communicate as if they are on the same physical network.

25. Which of the following is a web application vulnerability?

a) Cross-site scripting (XSS)

b) DNS spoofing

c) SYN flood

d) Ping of Death

Answer: a) Cross-site scripting (XSS)

Explanation: Cross-site scripting (XSS) is a vulnerability in web applications where an attacker can inject malicious code into a web page viewed by other users. DNS spoofing is a technique used to redirect network traffic to a malicious website by falsifying DNS records. SYN flood is a type of Denial-of-Service (DoS) attack where an attacker sends a flood of SYN packets to overwhelm a server. Ping of Death is a type of DoS attack where an attacker sends an oversized packet to crash a target system.

26. Which of the following is NOT an example of social engineering?

a) Phishing

b) Shoulder surfing

c) Denial of Service

d) Tailgating

Answer: c) Denial of Service

Explanation: Social engineering refers to the psychological manipulation of individuals to gain access to confidential information. Phishing, shoulder surfing, and tailgating are all examples of social engineering techniques. Denial of Service is a type of attack that overwhelms a system or network with traffic, preventing legitimate users from accessing it.

27. Which of the following is a technique used to detect network vulnerabilities by analyzing network traffic?

a) Penetration testing

b) Vulnerability scanning

c) Packet sniffing

d) Hash cracking

Answer: c) Packet sniffing

Explanation: Packet sniffing is a technique used to capture and analyze network traffic to detect vulnerabilities in the network. Penetration testing involves simulating an attack on a system to identify weaknesses, while vulnerability scanning involves using software tools to scan a system for known vulnerabilities. Hash cracking involves attempting to recover passwords from hashed values.

28. Which of the following is NOT an example of a password attack?

a) Brute force

b) Dictionary

c) SQL injection

d) Rainbow table

Answer: c) SQL injection

Explanation: Password attacks refer to techniques used to crack passwords to gain unauthorized access to a system. Brute force involves trying every possible combination of characters to guess the password, while dictionary attacks use a list of common words and phrases to guess the password. Rainbow tables are precomputed tables of hashes used to crack passwords quickly. SQL injection is a type of attack that exploits vulnerabilities in web applications to gain access to databases.

29. Which of the following is NOT an example of a wireless network attack?

a) Rogue access point

b) Evil twin

c) Packet sniffing

d) SQL injection

Answer: d) SQL injection

Explanation: Wireless network attacks refer to techniques used to exploit vulnerabilities in wireless networks to gain unauthorized access. Rogue access points and evil twins are examples of attacks that involve setting up a fake wireless access point to trick users into connecting to it. Packet sniffing is a technique used to capture and analyze network traffic. SQL injection is not a wireless network attack but rather a web application attack.

30. Which of the following is a type of malware that is designed to spread rapidly across a network?

a) Adware

b) Spyware

c) Trojan

d) Worm

Answer: d) Worm

Explanation: A worm is a type of malware that is designed to spread rapidly across a network by exploiting vulnerabilities in the network or by tricking users into running malicious code. Adware is malware that displays unwanted advertisements, while spyware is malware that collects user data without their knowledge or consent. Trojans are malware that masquerades as legitimate software to trick users into installing and running them.

31. The attacker copies the target's password file and then tries to crack passwords in his system at a different location. What type of password attack that performed?

A. Active Online Attack
B. Passive Online Attack
C. Non-Electronic Attack
D. Offline Attack

Correct Answer: D

Option D: correct The attacker copies the target's password file and then tries to crack passwords in his system at a different location

32. The company implements a security policy that has no restriction on the usage of system resources. What type of security policy did the company perform?

A. Promiscuous policy
B. Permissive policy
C. Prudent policy
D. Paranoid policy

Correct Answer: A

Option A: correct The promiscuous Policy has no restriction on the usage of system resources.

33. It is a kind of malware (malicious software) that gets activated upon users' certain predefined actions. When activated, it can grant attackers unrestricted access or control of all data stored on compromised information systems and can cause potentially immense damage. Which of the following terms best matches the definition?

A. Virus
B. Trojan
C. Ransomware
D. Worm

Correct Answer: B

Option B: correct Trojan is a program in which the malicious or harmful code is contained inside apparently harmless programming or data in such a way that it can get control and cause damage, such as ruining the file allocation table on your hard disk.

34. Server Administrator configures access settings for users to authenticate first before accessing web pages. Which requirement of information security is addressed by implementing the configuration?

A. Integrity
B. Availability
C. Confidentiality
D. Scalability

Correct Answer: C

Option C : correct Confidentiality means that only authorized persons can work with and see our infrastructure's digital resources

35. An organization allows employees to work from the outside network to access the data for a specific purpose. Which technology should be implemented to ensure data confidentiality as data is transmitted?

A. Telnet
B. VLAN
C. WPA2
D. VPN

Correct Answer: D

Option D : correct A virtual private network (VPN) extends a private network across a public network and enables users to send and receive data across shared or public networks with secure access to the private network

36. Attackers use image files to hide some information for malicious purposes. What type of technique did the attacker perform?

A. Spyware
B. Cryptography
C. Steganography
D. Backdoor

Correct Answer: C

Option C : correct Steganography refers to the art of hiding data ” behind ” other data without the target’s knowledge. Steganography hides the existence of the message. It replaces bits of unused data into the usual files such as graphic, sound, text, audio and video with some other surreptitious bits

37. Which Intrusion Detection System is the best applicable to analyze the system’s behavior for Desktop PC or Server?

A. HIDS
B. NIDS
C. Firewall
D. Antivirus

Correct Answer: A

Explanation

Option A : correct HIDS (Host-based Intrusion Detection System) analyze each system’s behavior and applicable on Desktop PC or Server

38. What is the purpose of a demilitarized zone on a network?

A. Protecting the network devices
B. Provide detection for malicious traffic on the network
C. Provide security on servers
D. Providing security to the internal network and only provide direct access to DMZ nodes

Correct Answer: D

Option D : correct DMZ is a small network placed as a neutral zone between the internal (trusted) network and external (untrusted) network to prevent an outsider from accessing the internal network directly.

39. Which of the following types of firewall inspects specific traffic such as http:get or post?

A. Packet filtering firewall
B. Application-level firewall
C. Circuit-level gateway firewall
D. Stateful Multilayer Inspection

Correct Answer: B

Option B : correct Application-level firewall (proxies) is filter packets at the application layer of the OSI model. This firewall inspect specific traffic on application such as http:get or post

40. The system administrator uses virus detection to prevent viruses on the system. He uses a tool for monitoring system operation requests that are written to disk. What is the virus detection method that the system administrator performs?

A. Scanning
B. Interception
C. Code Emulation
D. Integrity Checking

Correct Answer: B

Option B : correct The interceptors monitors system operation requests that are written to disk

41. Hyena is a tool to manages and secures Windows operating systems and uses a Windows Explorer-style interface for all operations. It shows shares and user login names for Windows servers and domain controllers. What is the purpose of using this tool?

A. NETBIOS Enumeration
B. LDAP Enumeration
C. SNMP Enumeration
D. SMTP Enumeration

Correct Answer: A

Explanation

Option A: correct Hyena is tool for NETBIOS Enumeration

42. Hashing is generating a value or values from a string of text using a mathematical function. Which of the following is assured by the use of a hash?

A. Confidentiality
B. Integrity
C. Availability
D. Authentication

Correct Answer: B

Option B: correct The main role of a cryptographic hash function is to provide integrity in document management. Integrity ensures an only authorized person can modify the data.

43. Domain Name System (DNS) has a few types of records. One type of them is AAAA Record. What is the purpose of the AAAA Record ?

A. IPv4 address resolution record
B. IPv6 address resolution record
C. Mail exchange record
D. Text record

Correct Answer: B

Option B: correct AAA is used for Returns, a 128-bit IPv6 address, most commonly used to map hostnames to the host's IP address.

44. CVSS is a published standard that provides an open framework for communicating the characteristics and impacts of IT vulnerabilities. CVSS assessment consists of three metrics for measuring vulnerabilities. Which of the following is the best definition of base metric?

A. Represents the inherent qualities of a vulnerability
B. Represents the vulnerabilities that are based on a particular environment or implementation
C. Represents the features that keep on changing during the lifetime of vulnerability
D. Represent the type of vulnerability

Correct Answer: A

Explanation

Option A : correct Base metric represents the inherent qualities of a vulnerability

45. Which type of hacker performs an attack on the system by using tools and knowledge found on the internet?

A. White Hat
B. Grey Hat
C. Black Hat
D. Script Kiddies

Correct Answer: D

Option D : correct Unskilled hackers, hacking and compromising system using tools are the scripts made by real hackers

46. Which of the following OSI layers is the packet filtering firewall work on?

A. Application
B. Application, Presentation, Session
C. Physical, Data Link
D. Data Link, Network, Transport

Correct Answer: D

Option D : correct Please see the table below

OSI Layer	Firewall Technology
Application	▪ Virtual Private Network (VPN) ▪ Application Proxies
Presentation	▪ Virtual Private Network (VPN)
Session	▪ Virtual Private Network (VPN) ▪ Circuit-level Gateway
Transport	▪ Virtual Private Network (VPN) ▪ Packet Filtering
Network	▪ Virtual Private Network (VPN) ▪ Network Address Translation (NAT) ▪ Packet Filtering ▪ Stateful Multilayer Inspection
Data Link	▪ Virtual Private Network (VPN) ▪ Packet Filtering
Physical	▪ Not Applicable

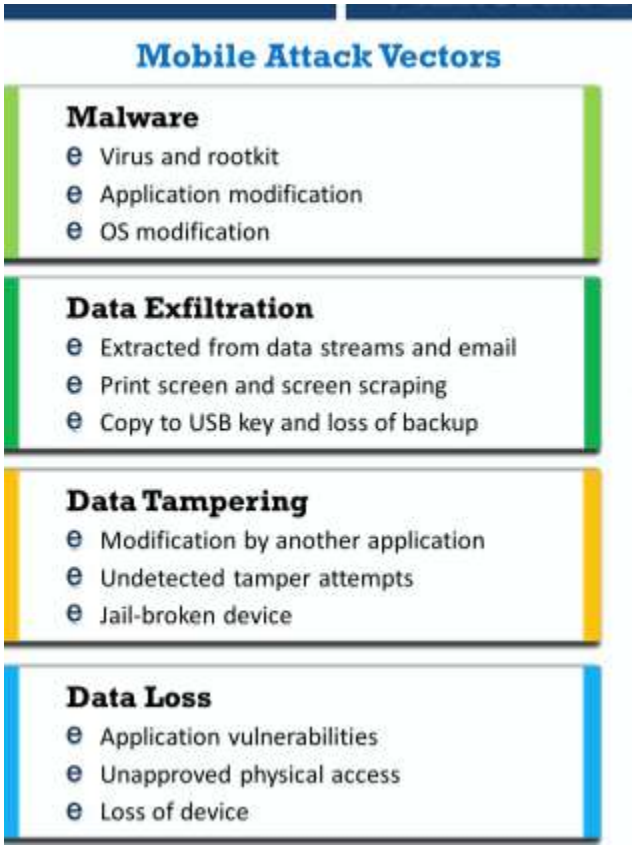
47. The enormous usage of mobile devices has grabbed the attention of attackers. Mobile devices access many of the resources that traditional computers use. Apart from that, mobile devices also have some unique features that add new attack vectors and protocols to the mix. Which of the following are mobile attack vectors?

A. Malware
B. Data Exfiltration
C. Data Tampering
D. Data Breaking

Correct Answers: A, B, and C

Explanation

Options A, B & C: correct Mobile attack vectors shown the picture below:



48. Which of the following protocol used to ensure security in transferring files across the network?

A. SSL
B. HTTP
C. TLS
D. SFTP

Correct Answer: D

Option D: correct SFTP is the protocol to ensure security in file transfer across the network

49. How to detect a honeypot that running on VMWare?

A. analyzing outgoing packets
B. Looking for MAC Address range on IEEE standard
C. Looking for specific TCP/IP parameters such as TTL, RTT, and, TCP timestamp
D. using time-based TCP fingerprinting method

Correct Answer: B

Option B: correct It is used to detect honeypots running on VMware

50. XYZ company uses 10.20.29.0/27 for the local network. Which of the following subnet mask in this network?

A. 255.255.255.0
B. 255.255.255.252
C. 255.255.255.248
D. 255.255.255.224

Correct Answer: D

Option D: correct It is a subnet mask for /27 prefix

51. In the Linux system, you want to view firewall logs to evaluate network traffic. It would be best if you searched the specific logs with fast and efficient. Which command-line utility are you most likely to use?

A. Notepad
B. Nano
C. Gedit
D. Grep

Correct Answer: D

Option D: correct grep is a command-line utility for searching plain-text data sets for lines that match a regular expression

52. A pen-tester is attacking wireless networks using fake authentication and ARP request injection. Which tools should be used by a pen-tester?

A. Aircrack-ng
B. Aireplay-ng
C. Airman-ng
D. Wireshark

Correct Answer: B

Option B: correct It is used for traffic generation fake authentication packet replay and ARP request injection.

53. It is the process of replacing unwanted bits in an image and its source files with the secret data. Which of the term being described?

A. Spyware
B. Cryptography
C. Steganography
D. Backdoor

Correct Answer: C

Option C: correct Steganography refers to the art of hiding data ” behind ” other data without the target’s knowledge. Steganography hides the existence of the message. It replaces bits of unused data into the usual files such as graphics, sound, text, audio, and video with some other surreptitious bits

54. Which protocol is used for setting up secure channels between two devices, typically in VPNs?

A. PPP
B. IPSEC
C. WPA
D. WEP

Correct Answer: B

55. John the Ripper is a technical assessment tool used to test the weakness of which of the following?

A. Usernames
B. File permissions
C. Firewall rulesets
D. Passwords

Correct Answer : D

Option D: correct John the ripper is the tool for brute force password attack. It is used to find a password combination.

56. Which of the following is NOT one of the five phases of ethical hacking?

A. Reconnaissance

B. Gaining Access

C. Maintaining Access

D. Encryption

Answer: D. Encryption Explanation: The five phases are Reconnaissance, Scanning, Gaining Access, Maintaining Access, and Covering Tracks. Encryption is not a phase

57. What does 'white hat' hacker mean?

A. Malicious hacker

B. State-sponsored hacker

C. Script kiddie

D. Ethical hacker

Answer: D. Ethical hacker Explanation: A white hat hacker performs security testing with permission to improve defenses.

58. Which framework maps attacker tactics and techniques and is commonly used in CEH?

A. COBIT

B. MITRE ATT&CK;

C. ISO 9001

D. NIST CSF

Answer: B. MITRE ATT&CK; Explanation: MITRE ATT&CK; catalogs adversary tactics/techniques used by security professionals for threat modelling

59. Which law is primarily about data protection in Europe?

A. DMCA

B. HIPAA

C. GDPR

D. PCI-DSS

Answer: C. GDPR Explanation: GDPR is the EU regulation for data protection and privacy

60. What is 'footprinting' in ethical hacking?

A. Encrypting data

B. Exploiting a vulnerability

C. Crashing a service

D. Gathering information about a target

Answer: D. Gathering information about a target Explanation: Footprinting is passive or active information gathering about a target before attacks

61. Which tool is commonly used for DNS and WHOIS lookups during footprinting?

A. John the Ripper

B. Metasploit

C. whois

D. Nmap

Answer: C. whois Explanation: whois queries domain registrant and DNS information useful during footprinting

62. Which Google operator helps find filenames on websites?

A. inurl:

B. intitle:

C. filetype:

D. site:

Answer: C. filetype: Explanation: filetype: lets you search for specific file extensions (e.g., filetype:pdf)

63. Dark web footprinting primarily uses which protocol/service to access content?

A. SMTP

B. HTTP

C. FTP

D. Onion network/Tor

Answer: D. Onion network/Tor Explanation: The Tor network (.onion) is used to access dark web services

64. What does a TCP SYN scan primarily detect?

A. Open ports

B. Weak passwords

C. Malware signatures

D. Expired certificates

Answer: A. Open ports Explanation: SYN scans detect which TCP ports respond, indicating open services

65. Which tool is most associated with network scanning and port detection?

A. Burp Suite

B. Nmap

C. Wireshark

D. GDB

Answer: B. Nmap Explanation: Nmap is the industry-standard port and host discovery tool

66. Which scan type attempts to remain stealthy by not completing TCP handshakes?

A. TCP Connect scan

B. SYN scan

C. ACK scan

D. UDP scan

Answer: B. SYN scan Explanation: SYN scan sends SYN and analyzes replies but doesn't complete handshake (half-open), making it stealthier.

67. Service version detection in Nmap uses which switch?

A. -sS

B. -A

C. -sV

D. -O

Answer: C. -sV Explanation: -sV enables version detection to identify software/service versions

68. Which protocol is commonly enumerated to find Windows share info?

A. HTTP

B. SMB

C. BGP

D. ICMP

Answer: B. SMB Explanation: SMB is used for Windows file/service shares and is often enumerated.

69. What does SNMP enumeration allow you to discover?

A. Network device info and configs

B. SSL certificates

C. User passwords only

D. Only email addresses

Answer: A. Network device info and configs Explanation: SNMP can reveal device configurations, running services, and objects via community strings.

70. LDAP enumeration is mainly useful for discovering what?

A. Active Directory user accounts

B. MAC addresses

C. Router firmware

D. Database contents

Answer: A. Active Directory user accounts Explanation: LDAP/AD exposes user/group information useful for attacks.

71. Which tool can be used for NetBIOS and SMB enumeration?

A. Hydra

B. Enum4Linux

C. Nikto

D. Hashcat

Answer: B. Enum4Linux Explanation: Enum4Linux queries NetBIOS/SMB/AD data on Windows hosts.

72. A CVE identifier is used for what purpose?

A. Scanning ports

B. Describing policies

C. Encrypting traffic

D. Classifying vulnerabilities

Answer: D. Classifying vulnerabilities

Explanation: CVE assigns unique identifiers to publicly known vulnerabilities.

73. What does CVSS score indicate?

A. Severity of vulnerability

B. Network latency

C. Encryption strength

D. User count

Answer: A. Severity of vulnerability

Explanation: CVSS quantifies severity to prioritize remediation.

74. Which tool performs automated vulnerability scanning?

A. Metasploit

B. Nessus

C. John the Ripper

D. Wireshark

Answer: B. Nessus Explanation: Nessus is widely used for vulnerability scanning and reporting.

75. Zero-day vulnerabilities are best described as:

A. Only in open-source software

B. Well-known fixes available

C. Non-exploitable

D. Unknown to vendor and unpatched

Answer: D. Unknown to vendor and unpatched Explanation: Zero-day means no patch or vendor fix is available yet

76. What is privilege escalation?

A. Crashing a program

B. Gaining higher-level permissions

C. Scanning ports

D. Encrypting files

Answer: B. Gaining higher-level permissions

Explanation: Privilege escalation is obtaining higher access rights on a compromised system.

77. Which framework is commonly used to exploit systems and post-exploitation?

A. Metasploit

B. Nmap

C. OpenVAS

D. Wireshark

Answer: A. Metasploit

Explanation: Metasploit is a penetration testing framework used to exploit and post-exploit.

78. Buffer overflow attacks exploit what?

A. Open ports

B. DNS records

C. Weak SSL certs

D. Excessive memory writes

Answer: D. Excessive memory writes

Explanation: Buffer overflows overwrite memory leading to arbitrary code execution.

79. Clearing logs on Windows to hide tracks commonly targets which log?

A. Event Viewer logs

B. Bash history

C. dpkg logs

D. /var/log/syslog

Answer: A. Event Viewer logs

Explanation: Windows Event Logs are typical targets for attackers seeking to hide activity

80. Which of these is ransomware's main goal?

A. Scan ports

B. Steal CPU cycles

C. Encrypt user data for ransom

D. Improve system performance

Answer: C. Encrypt user data for ransom

Explanation: Ransomware encrypts data and demands payment for decryption.

81. Fileless malware typically resides where?

A. In router firmware

B. In memory or legitimate processes

C. On backup tapes

D. On disk as EXE

Answer: B. In memory or legitimate processes

Explanation: Fileless malware executes in memory and uses legitimate processes making detection harder.

82. Which technique helps analyze malware dynamically?

A. Checking port list

B. Passive DNS

C. Sandboxing and dynamic analysis

D. Static signature matching only

Answer: C. Sandboxing and dynamic analysis

Explanation: Dynamic analysis runs malware in a controlled environment to observe behavior.

83. What is a Trojan?

A. A firewall

B. Malware disguised as legitimate software

C. A hashing algorithm

D. A network scanner

Answer: B. Malware disguised as legitimate software

Explanation: Trojans hide malicious payloads inside seemingly legitimate programs

84. What is packet sniffing used for?

A. Generating certificates

B. Encrypting traffic

C. Capturing network packets for analysis

D. Creating VMs

Answer: C. Capturing network packets for analysis

Explanation: Sniffers capture packets to analyze traffic, headers, payloads.

85. Which tool is the industry standard for packet capture and analysis?

A. Wireshark

B. John the Ripper

C. Metasploit

D. Nmap

Answer: A. Wireshark

Explanation: Wireshark is used to capture and analyze network packets.

86. ARP poisoning is commonly used to achieve what?

A. Open SMTP relay

B. DNS registration

C. SSH tunneling

D. Man-in-the-middle (MITM)

Answer: D. Man-in-the-middle (MITM)

Explanation: ARP poisoning redirects traffic to attacker enabling MITM attacks.

87. Promiscuous mode on a NIC allows:

A. Capture all packets on the network segment

B. Disable NIC

C. Only outgoing packets

D. Faster CPU

Answer: A. Capture all packets on the network segment

Explanation: Promiscuous mode makes the NIC accept all packets seen on the segment

88. Which social engineering attack uses a direct call or message pretending to be support?

A. SQL Injection

B. Vishing

C. DDoS

D. Pharming

Answer: B. Vishing

Explanation: Vishing uses voice calls to trick victims into revealing info.

89. Phishing attacks typically aim to:

A. Increase bandwidth

B. Format disk

C. Install antivirus

D. Trick users to reveal credentials

Answer: D. Trick users to reveal credentials

Explanation: Phishing uses deceptive messages to capture sensitive data.

90. Pretexting relies on:

A. Certificate pinning

B. Network sniffing

C. A fabricated scenario to gain trust

D. Random scanning

Answer: C. A fabricated scenario to gain trust

Explanation: Pretexting builds plausible stories to manipulate targets.

91. Tailgating is:

A. Sending spam

B. Port scanning

C. Hacking web apps

D. Following authorized person into restricted area

Answer: D. Following authorized person into restricted area

Explanation: Tailgating is physical social engineering to enter secure areas

92. What is the main purpose of a DDoS attack?

A. Bypass firewall rules

B. Escalate privileges

C. Overwhelm resources to cause downtime

D. Encrypt data at rest

Answer: C. Overwhelm resources to cause downtime

Explanation: DDoS floods targets to exhaust resources and disrupt services.

93. A botnet consists of:

A. Encrypted databases

B. A network of compromised machines under attacker control

C. Only routers

D. Only IoT devices

Answer: B. A network of compromised machines under attacker control

Explanation: Botnets are many compromised systems coordinated for attacks.

94. Which tool is historically known for network stress testing (but illegal if misused)?

A. Burp

B. Nmap

C. LOIC

D. Wireshark

Answer: C. LOIC

Explanation: LOIC was used in many DDoS operations; misuse is illegal.

95. What mitigation helps protect against DDoS?

A. Traffic filtering and rate-limiting

B. Using weak passwords

C. Using single small server

D. Disabling DNS

Answer: A. Traffic filtering and rate-limiting

Explanation: Rate-limiting, scrubbing and filtering reduce DDoS impact

96. Session hijacking targets what to impersonate a user?

A. IP address only

B. MAC address

C. Session ID or token

D. Hostname

Answer: C. Session ID or token

Explanation: Hijackers steal or guess session tokens to impersonate users.

97. Which protocol weakness made early web session hijacking easier?

A. Strong encryption

B. Two-factor auth

C. Use of predictable session IDs

D. HSTS

Answer: C. Use of predictable session IDs

Explanation: Predictable session IDs allowed attackers to guess/steal sessions.

98. Cookie theft via XSS primarily enables:

A. SQL injection

B. Log wiping

C. Port scanning

D. Session hijacking

Answer: D. Session hijacking

Explanation: XSS can steal cookies/session tokens enabling session takeover.

99. TLS prevents many session hijacking attacks by:

A. Blocking HTTP

B. Deleting sessions

C. Hiding cookies entirely

D. Encrypting session tokens in transit

Answer: D. Encrypting session tokens in transit

Explanation: TLS encrypts data in transit, protecting session tokens from interception

100. Evasion techniques aim to:

A. Install honeypots

B. Speed up detection

C. Patch systems

D. Make detection harder for IDS/AV

Answer: D. Make detection harder for IDS/AV

Explanation: Evasion reduces visibility to detection systems.

101. Tunneling over HTTPS often bypasses which control?

A. Printer queue

B. Physical lock

C. Power supply

D. IDS signatures

Answer: D. IDS signatures

Explanation: Encrypted tunnels over HTTPS can conceal malicious traffic from signature-based IDS.

102. Honeypots are used to:

A. Host production DB

B. Increase vulnerability

C. Encrypt traffic

D. Attract and study attackers

Answer: D. Attract and study attackers

Explanation: Honeypots lure attackers to gather intelligence and signatures.

103. Which tool can help bypass simple firewall rules using SSH?

A. Nikto

B. Hydra

C. Nmap

D. sshuttle

Answer: D. sshuttle

Explanation: sshuttle creates transparent proxying over SSH, bypassing some firewall restrictions

104. What is a common web server attack vector?

A. Directory traversal

B. MAC flooding

C. ARP poisoning

D. Buffer overflow only on routers

Answer: A. Directory traversal

Explanation: Directory traversal lets attacker read files outside webroot if not protected.

105. Which server daemon is commonly targeted on Linux web servers?

A. smbd

B. sshd

C. apache/httpd

D. winrm

Answer: C. apache/httpd

Explanation: Apache httpd is a common web server target if misconfigured.

106. Cache poisoning attacks aim to:

A. Encrypt disk

B. Poison cache entries to serve malicious content

C. Change MAC

D. Increase CPU

Answer: B. Poison cache entries to serve malicious content

Explanation: Cache poisoning manipulates caches (e.g., DNS, web) to redirect users.

107. Web server fingerprinting helps discover:

A. Server software and versions

B. User passwords

C. Database schemas

D. Wireless SSIDs

Answer: A. Server software and versions

Explanation: Fingerprinting reveals server type/version to find known vulnerabilities.

108. OWASP Top 10 is primarily about:

A. Email encryption

B. Web application security risks

C. Network cabling

D. Physical security

Answer: B. Web application security risks

Explanation: OWASP Top 10 lists the most critical web app security risks.

109. Cross-Site Scripting (XSS) primarily exploits:

A. DNS records

B. Server CPU

C. Client-side scripts

D. Router firmware

Answer: C. Client-side scripts

Explanation: XSS injects scripts that execute in victims' browsers.

110. Which tool is popular for web application testing and proxying?

A. Burp Suite

B. John the Ripper

C. Aircrack-ng

D. Nmap

Answer: A. Burp Suite

Explanation: Burp Suite provides web proxying, scanning, and exploitation tools.

111. CSRF attacks exploit which weakness?

A. Broken SSH keys

B. Unpatched BIOS

C. Lack of server-side CSRF protections and authenticated state

D. Weak WiFi encryption

Answer: C. Lack of server-side CSRF protections and authenticated state

Explanation: CSRF tricks authenticated users into submitting unwanted requests without CSRF tokens

112. An SQL injection vulnerability allows an attacker to:

A. Bypass BIOS

B. Manipulate database queries

C. Crack WiFi

D. Send emails

Answer: B. Manipulate database queries

Explanation: SQLi allows injected input to alter database queries and reveal data.

113. Which SQLi type uses database error messages to extract data?

A. Error-based SQLi

B. Union-based SQLi

C. Blind SQLi

D. Out-of-band SQLi

Answer: A. Error-based SQLi

Explanation: Error-based uses DB errors to leak data.

114. Prepared statements help prevent SQLi by:

A. Encrypting DB

B. Disabling SQL

C. Separating code and data

D. Changing ports

Answer: C. Separating code and data

Explanation: Prepared statements bind parameters, preventing user input from becoming executable SQL.

115. Union-based SQLi leverages which SQL keyword?

A. SELECT

B. DROP

C. UNION

D. JOIN

Answer: C. UNION

Explanation: UNION combines query results enabling data extraction via SQLi

116. Which protocol secures modern Wi-Fi networks?

A. WEP

B. Telnet

C. WPA2/WPA3

D. FTP

Answer: C. WPA2/WPA3

Explanation: WPA2 and WPA3 are current Wi-Fi security standards; WEP is insecure.

117. What is a rogue access point?

A. A printer

B. Authorized AP

C. Malicious AP mimicking a legit SSID

D. A firewall rule

Answer: C. Malicious AP mimicking a legit SSID

Explanation: Rogue APs impersonate legitimate networks to capture traffic.

118. Which attack cracks pre-shared keys by capturing 4-way handshake?

A. XSS

B. SQLi

C. Handshake capture and offline cracking

D. ARP poisoning

Answer: C. Handshake capture and offline cracking

Explanation: Capture 4-way handshake and brute-force PSK offline.

119. WPS PIN vulnerability primarily affects:

A. WPS-enabled routers

B. WEP only

C. SSH servers

D. Bluetooth devices

Answer: A. WPS-enabled routers

Explanation: WPS PIN flaws allow brute-force attacks on routers' WPS feature

120. Android APK files are packaged as:

A. .apk

B. .rpm

C. .iso

D. .exe

Answer: A. .apk

Explanation: Android apps are distributed as .apk packages.

121. What does 'rooting' an Android device provide?

A. Encrypted calls

B. Faster WiFi

C. Elevated administrative privileges

D. Less storage

Answer: C. Elevated administrative privileges

Explanation: Rooting grants superuser access to the OS.

122. Mobile app sandboxing helps by:

A. Installing malware

B. Crashing phone

C. Removing network interfaces

D. Isolating app data and permissions

Answer: D. Isolating app data and permissions

Explanation: Sandboxing limits app access to system resources and other apps.

123. SMiShing targets victims via which channel?

A. Email attachments

B. DNS

C. Physical mail

D. SMS messages

Answer: D. SMS messages

Explanation: SMiShing is phishing delivered via SMS

124. IoT devices commonly present which security issue?

A. Impossible to hack

B. Automatic patches always enabled

C. Unlimited CPU

D. Default credentials and weak update mechanisms

Answer: D. Default credentials and weak update mechanisms

Explanation: Many IoT devices ship with default creds and poor patching.

125. OT (Operational Technology) differs from IT because it:

A. Manages industrial processes and controls physical systems

B. Only uses cloud

C. Is always offline

D. Uses only Linux

Answer: A. Manages industrial processes and controls physical systems

Explanation: OT focuses on ICS/SCADA controlling physical processes.

126. Which protocol is common in industrial control systems (ICS)?

A. Bluetooth

B. SMTP

C. Modbus

D. HTTP only

Answer: C. Modbus

Explanation: Modbus is widely used in ICS and often lacks security.

127. IoT device firmware analysis is useful to find:

A. Network latency

B. Printer drivers

C. Hidden backdoors and credentials

D. Only UI issues

Answer: C. Hidden backdoors and credentials

Explanation: Firmware often contains hardcoded credentials or vulnerabilities

128. Which cloud service model provides operating systems and runtime to users?

A. DaaS

B. SaaS

C. IaaS

D. PaaS

Answer: D. PaaS

Explanation: PaaS delivers platforms and runtimes; IaaS provides infrastructure (VMs).

129. Misconfigured S3 buckets commonly lead to:

A. Encrypted traffic

B. Data exposure

C. Blocked DNS

D. Faster downloads

Answer: B. Data exposure

Explanation: Public S3 buckets can expose sensitive data.

130. IAM in cloud environments stands for:

A. Internal API Management

B. Internet Access Management

C. Immediate Admin Mode

D. Identity and Access Management

Answer: D. Identity and Access Management

Explanation: IAM controls identities, roles, and permissions in cloud platforms.

131. Container breakout vulnerabilities allow attackers to:

A. Encrypt container

B. Escape container isolation to access host

C. Disable logging

D. Increase container speed

Answer: B. Escape container isolation to access host

Explanation: Container breakout compromises host by escaping container boundaries

132. Symmetric encryption uses:

A. No key

B. Different keys for sender/receiver

C. Public/private key pair

D. Same key for encryption and decryption

Answer: D. Same key for encryption and decryption Explanation: Symmetric uses one shared secret key; asymmetric uses key pairs.

133. Which algorithm is asymmetric?

A. 3DES

B. RSA

C. Blowfish

D. AES

Answer: B. RSA

Explanation: RSA is an asymmetric public-key algorithm.

134. What does PKI manage?

A. Network routes

B. Physical keys

C. Public keys, certificates, and trust relationships

D. Passwords only

Answer: C. Public keys, certificates, and trust relationships Explanation: PKI issues and manages digital certificates and trust.

135. A hash function is designed to be:

A. Reversible

B. Symmetric

C. One-way and collision-resistant ideally

D. Easily decrypted

Answer: C. One-way and collision-resistant ideally Explanation: Hashes are one-way functions; collisions should be hard to find